

Lab 1: Risk Assessment Methodologies - Technical Scanning to GRC Analysis

Course: GRC103 - Risk Assessment & Management

Student Name: JOY ORILADE

Date: 11TH APRIL, 2026

Instructor: Com Idris Aminu

PHASE 1 – STEP 1-3

```
icdffa@icdffa:~/grc-lab-week1/task1$ sudo nmap -sC -sV -oN initial_scan -Pn 192.168.111.130
Nmap scan report for 192.168.111.130
Host is up (0.00077s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
FTP server status:
  Connected to 192.168.111.129
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  vsFTPd 2.3.4 - secure, fast, stable
End of status
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_ 1024 60:0f:cf:e1:c0:5f:6a:74:06:90:24:fa:c4:d5:6c:cd (DSA)
23/tcp    open  telnet   Linux telnetd
```

```
{
  "http-title": "Apache Tomcat/Coyote JSP engine 1.1",
  "http-favicon": "Apache Tomcat",
  "http-server-header": "Apache-Coyote/1.1",
  "MAC-Address": "08:0C:29:B6:70:1a (VMware)",
  "Service-Info": {
    "Hosts": "metasploitable.localdomain, irc.Metasploitable.LAN",
    "OSs": "Unix, Linux",
    "CPE": "cpe:/o:linux:linux_kernel"
  },
  "Host-script-results": {
    "snmp-security-mode": null,
    "account-used": "guest",
    "authentication-level": "user",
    "challenge-response": "supported",
    "message-signing": "disabled (dangerous, but default)",
    "clock-skew": {
      "mean": "1h00m00s",
      "deviation": "2h00m02s",
      "median": "-1s"
    },
    "snmp-discovery": null,
    "OS": "Unix (Samba 3.0.20-Debian)",
    "Computer-name": "metasploitable",
    "NetBIOS-computer-name": null,
    "Domain-name": "localdomain",
    "FQDN": "metasploitable.localdomain",
    "System-time": "2026-04-11T22:23:45-04:00",
    "snmp2-time": "Protocol negotiation failed (SNMP2)",
    "snbtstat": {
      "NetBIOS-name": "METASPLOITABLE",
      "NetBIOS-user": "<unknown>",
      "NetBIOS-MAC": "<unknown>"
    }
  },
  "Service-detection-performed": "Please report any incorrect results at https://nmap.org/submit/.",
  "Nmap-done": "3 IP address (1 host up) scanned in 177.40 seconds"
}
```

```
icdffa@icdffa:~/grc-lab-week1/task1$ sudo nmap -sC -sV -oN initial_scan -Pn 192.168.111.130
Nmap scan report for 192.168.111.130
Host is up (0.00077s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
FTP server status:
  Connected to 192.168.111.129
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  vsFTPd 2.3.4 - secure, fast, stable
End of status
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_ 1024 60:0f:cf:e1:c0:5f:6a:74:06:90:24:fa:c4:d5:6c:cd (DSA)
23/tcp    open  telnet   Linux telnetd
```

```
icdffa@icdffa:~/grc-lab-week1/task1$ sudo nmap -sC -sV -oN initial_scan -Pn 192.168.111.130
Nmap scan report for 192.168.111.130
Host is up (0.00077s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
FTP server status:
  Connected to 192.168.111.129
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  vsFTPd 2.3.4 - secure, fast, stable
End of status
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_ 1024 60:0f:cf:e1:c0:5f:6a:74:06:90:24:fa:c4:d5:6c:cd (DSA)
23/tcp    open  telnet   Linux telnetd
25/tcp    open  smtp      Postfix smtpd
|_ssl-date: 2026-04-11T22:23:47+00:00; 0s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outsi
de US/countryName=XX
|_ Not valid before: 2020-03-17T14:07:45
|_ Not valid after: 2020-04-10T14:07:45
|_ssl-v2:
|_SSLv2 supported
|_ciphers:
|_SSLv2_DES_192_EDE3_CBC_WITH_MD5
|_SSLv2_RC4_128_EXPORT40_WITH_MD5
|_SSLv2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSLv2_DES_64_CBC_WITH_MD5
```

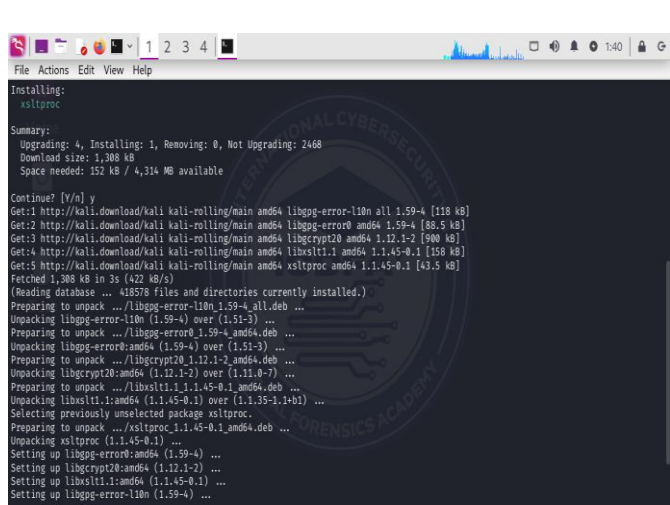

PHASE 2:

STEP 1 - nikto -h <http://192.168.111.130> -o nikto_scan.txt

[illegible]

```
Applications View Help
$ apt-get install nixto
Unpacking nixto (1:2.4.8-khalil) ...
Setting up perl-modules-5.40 (5.40.1-7) ...
Setting up libperl5.40:smdm64 (5.40.1-7) ...
Setting up perl (5.40.1-7) ...
Setting up libhtml-writer-perl (0.900-2) ...
Setting up libhtml-nomsgspace-support-perl (1.12-2) ...
Setting up libhtml-tree-perl (2.55.1-3) ...
Setting up libdigest-perl-md5-perl (1.91-1) ...
Setting up libhtml-san-base-perl (1.40-1) ...
Setting up libhtml-san-perl (1.82-defag-4) ...
update-perl-sax-parsers: Registering Perl SAX parser XML::SAX::PurePerl with priority 10 ...
update-perl-sax-parsers: Updating overall Perl SAX parser modules info file ...
Creating config file /etc/perl/XML/SAX/ParserDetails.ini with new version
Setting up libhtml-libxml-perl (2.0207+dfsg+really+2.0133-7) ...
update-perl-sax-parsers: Registering Perl SAX parser XML::LIBXML::SAX::Parser with priority 50 ...
update-perl-sax-parsers: Registering Perl SAX parser XML::LIBXML::SAX with priority 50 ...
update-perl-sax-parsers: Updating overall Perl SAX parser modules info file ...
Replacing config file /etc/perl/XML/SAX/ParserDetails.ini with new version
Setting up libhtml-san-expat-perl (0.51-2) ...
update-perl-sax-parsers: Registering Perl SAX parser XML::SAX::Expat with priority 50 ...
update-perl-sax-parsers: Updating overall Perl SAX parser modules info file ...
Replacing config file /etc/perl/XML/SAX/ParserDetails.ini with new version
Setting up nixto (1:2.4.8-khalil) ...
Processing triggers for libc-bin (2.41-6) ...
Processing triggers for man-db (2.12.0-1) ...
Processing triggers for mailutils (3.15-1) ...
```

STEP 2 - nuclei -u http://< 192.168.111.130> -o nuclei_web_scan.txt



```
File Actions Edit View Help
1 2 3 4
Processing triggers for kali-menu (2025.11.3) ...

[icfca@icfca:~]$ ./grc-lab-week1/task1
./nuclei -target 192.168.111.138 -o nuclei_full_scan.txt

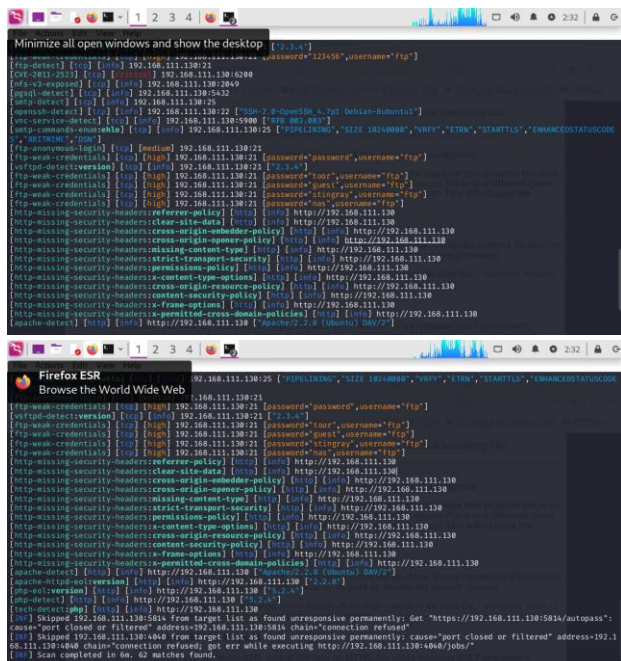
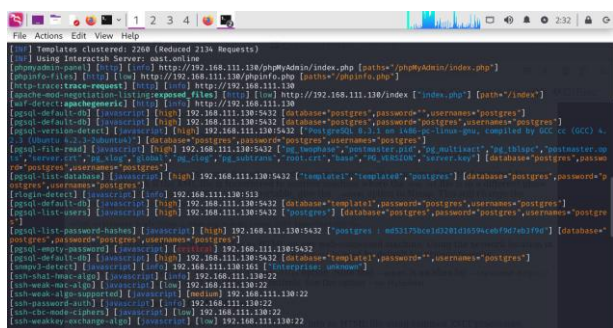
nuclei
v7.7.1
projectdiscovery.io

[INFO] nuclei-templates are not installed, installing...
[INFO] Your current nuclei-templates are outdated, latest is v10.4.1
[INFO] Successfully updated nuclei-templates (v10.4.1) to /home/icfca/.local/nuclei-templates. GoodLuck!

Nuclei Templates v10.4.1 Changelog

TOTAL ADDED MODIFIED REMOVED
13178 13178 0 0

[INFO] Found 1 templates with runtime error (use --validate flag for further examination)
[INFO] Current nuclei version: v7.7.1 (latest)
[INFO] Current nuclei-templates version: v10.4.1 (latest)
[INFO] New templates added in latest release: 76
[INFO] Templates loaded for current scan: 9959
[INFO] Executing 9959 signed templates from projectdiscovery/nuclei-templates
[INFO] Loading 12 unsigned templates for scan. Use with caution.
[INFO] Targets loaded for current scan: 1
```



Screenshot of the Nmap HTML report (initial_scan_report.html)

The collage displays five screenshots of an Nmap HTML report titled "Nmap Scan Report - Scanned at Sat Apr 11 23:20:20 2020".

Top Left Screenshot: Host Script Output

Script Name	Output
ssh-security-mode	account_sudo: guest authentication: Password user key_exchange: ecdh-sha2-nistp256 macrop_timing: disabled (dangerous, not default)
ssh-cipher	cipher: chacha20, encryption: 256GCM, mac: hmac-sha256
ssh-cv-knowning	(0) Size (bytes): 3, 2, 20 (Default) cipher: none, mac: hmac-sha256 key_exchange: none mac: none, mac: hmac-sha256 PRNG: metasploit32, localdomain Server: OpenSSH_8.2p1 Ubuntu-4ubuntu0.2
ssh-cv-knowning	(Protocol negotiation failed) (99%)
ssh-cv-knowning	SSH: OpenSSH_8.2p1 Ubuntu-4ubuntu0.2

Top Right Screenshot: Scan Summary

Scan Summary: 192.168.111.130

Scan Summary

Nmap 7.80 was initiated at Sat Apr 11 23:20:20 2020 with these arguments:
nmap -sS -sV -p- -oX /home/jcdfa/Desktop/initial_scan_report.html

Verbs: 0, Debug level: 0

Nmap done at Sat Apr 11 23:20:18 2020; 1 IP address (1 host up) scanned in 177.48 seconds

Middle Left Screenshot: Address

Address

- 192.168.111.130 (ipv4)
- 10.0.0.0/24 (v4)

Middle Right Screenshot: Ports

The 877 ports scanned but not shown below are in state: closed

Bottom Left Screenshot: Detailed Table

Port	State	Service	Version	Product	Device
22	open	ssh	OpenSSH	Ubuntu	Ubuntu
23	open	telnet	Linux telnetd		
25	open	smtp	Postfix smtpd		
80	open	http	Apache httpd		

Bottom Right Screenshot: Detailed Table

Port	State	Service	Version	Product	Device
22	open	ssh	OpenSSH	Ubuntu	Ubuntu
23	open	telnet	Linux telnetd		
25	open	smtp	Postfix smtpd		
80	open	http	Apache httpd		

Browser tabs: Nmap Scan Report x Nmap Scan Report x Nmap Scan Report x +

Address bar: file:///home/icdfa/Desktop/Nmap Scan Report - Sc... 90%

Navigation: ICDF Students Poeral Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

http-site	Metasploitable2 - Linux																																												
http-server-header	Apache/2.2.8 (Ubuntu) DAV/2																																												
111	tcp	open		rpcbind	syn-ack		2		RPC #100000																																				
rpcinfo	<table><tr><td>program</td><td>version</td><td>port/proto</td><td>service</td></tr><tr><td>100003</td><td>2,3,4</td><td>2049/tcp</td><td>nfs</td></tr><tr><td>100003</td><td>2,3,4</td><td>2049/udp</td><td>nfs</td></tr><tr><td>100005</td><td>1,2,3</td><td>35593/udp</td><td>mountd</td></tr><tr><td>100005</td><td>1,2,3</td><td>39225/tcp</td><td>mountd</td></tr><tr><td>100021</td><td>1,3,4</td><td>39204/tcp</td><td>nlockmgr</td></tr><tr><td>100021</td><td>1,3,4</td><td>59808/udp</td><td>nlockmgr</td></tr><tr><td>100024</td><td>1</td><td>47070/tcp</td><td>status</td></tr><tr><td>100024</td><td>1</td><td>48411/udp</td><td>status</td></tr></table>									program	version	port/proto	service	100003	2,3,4	2049/tcp	nfs	100003	2,3,4	2049/udp	nfs	100005	1,2,3	35593/udp	mountd	100005	1,2,3	39225/tcp	mountd	100021	1,3,4	39204/tcp	nlockmgr	100021	1,3,4	59808/udp	nlockmgr	100024	1	47070/tcp	status	100024	1	48411/udp	status
program	version	port/proto	service																																										
100003	2,3,4	2049/tcp	nfs																																										
100003	2,3,4	2049/udp	nfs																																										
100005	1,2,3	35593/udp	mountd																																										
100005	1,2,3	39225/tcp	mountd																																										
100021	1,3,4	39204/tcp	nlockmgr																																										
100021	1,3,4	59808/udp	nlockmgr																																										
100024	1	47070/tcp	status																																										
100024	1	48411/udp	status																																										
139	tcp	open		netbios-smb	syn-ack	Samba smbd	3.X - 4.X		workgroup: WORKGROUP																																				
445	tcp	open		netbios-smb	syn-ack	Samba smbd	3.0.20-Debian		workgroup: WORKGROUP																																				
512	tcp	open		exec	syn-ack	netkit-rsh rexecd																																							
513	tcp	open		login	syn-ack	OpenBSD or Solaris rlogind																																							
514	tcp	open		tzserverappd	syn-ack																																								
1090	tcp	open		java-rmi	syn-ack	GNU Classpath gmingregistry																																							
1524	tcp	open		bindshell	syn-ack	Metasploitable root shell																																							
2040	tcp	open		nfs	syn-ack		2-4		RPC #100003																																				
2121	tcp	open		ccproxy-ftp	syn-ack																																								
3306	tcp	open		mysql	syn-ack	MySQL	5.0.51a-3ubuntu5																																						
mysql-info	Protocol: 10																																												

Go to top

Toggle Closed Ports

Toggle Filtered Ports

Browser tabs: Nmap Scan Report x Nmap Scan Report x Nmap Scan Report x +

Address bar: file:///home/icdfa/Desktop/Nmap Scan Report - Sc... 90%

Navigation: ICDF Students Poeral Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

ssl-cert	Subject: commonName=ubuntu004-base.localdomain/organizationName=OC05A/state0=ProvinceName=There is no such thing outside US/countryName=XX Not valid before: 2018-03-17T14:07:45 Not valid after: 2018-04-10T14:07:45					
ssl-date	2026-04-11T22:23:16+00:00: -1s from scanner time.					
5900 tcp	open	vnc	syn-ack	VNC		protocol 3.3
vnc-info	Protocol version: 3.3 Security types: VNC Authentication (2)					
6000 tcp	open	X11	syn-ack			access denied
6667 tcp	open	irc	syn-ack	UnrealIRCd		
irc-info	users: 1 servers: 1 lusers: 1 lservers: 0 server: irc.Metasploitable.LAN version: Unreal3.2.8.1. irc.Metasploitable.LAN uptime: 0 days, 0: source ident: nmap source host: F80B66CE-AA0B0C7.FFFA5D49.IP error: Closing Link: yhodkjsqj[192.168.111.129] (Quit: yhodkjsqj)					
8009 tcp	open	ajp13	syn-ack	Apache Jserv		Protocol v1.3
ajp-methods	Failed to get a valid response for the OPTIONS request					
8180 tcp	open	http	syn-ack	Apache Tomcat/Coyote JSP engine	1.1	
http-title						

Browser tabs: Nmap Scan Report x Nmap Scan Report x Nmap Scan Report x +

Address bar: file:///home/icdfa/Desktop/Nmap Scan Report - Sc... 90%

Navigation: ICDF Students Poeral Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

8180 tcp	open	http	syn-ack	Apache Tomcat/Coyote JSP engine	1.1	
http-title	Apache Tomcat/5.5					
http-favicon	Apache Tomcat					
http-server-header	Apache-Coyote/1.1					

Host Script Output

Script Name	Output
smb-security-mode	account_used: guest authentication_level: user challenge_response: supported message_signing: disabled (dangerous, but default)
clock-skew	mean: 1h00m00s, deviation: 2h00m02s, median: -1s
smb-os-discovery	OS: Unix (Samba 3.0.20-Debian) Computer name: metasploitable NetBIOS computer name: Domain name: localdomain FQDN: metasploitable.localdomain System time: 2026-04-11T18:23:05-04:00
smb2-time	Protocol negotiation failed (SMB2)

Go to top
Toggle Closed Ports
Toggle Filtered Ports

PHASE 3

STEP 1

FINDING	AFFECTED SERVICE	CVE/REFERENCE	INHERENT RISK (L/M/H)	COMPLIANCE VIOLATION	BUSINESS IMPACT
Weak Default credentials	SSH, FTP	N/A	H	CIS 5.2, NIST CSF PR.AC-1	Unauthorized access, data theft
VsFTPD2.3.4 Backdoor	FTP	CVE-2011-2523	H	CIS 7.1 (Patch Mgt)	Full System compromise
Unencrypted Telnet Service	Telnet	N/A	H	NIST CSF PR.DS-2	Credential sniffing espionage
Default Credentials	SSH, FTP	N/A	H	CIS 5.2	Unauthorized access
FTP Access	FTP	N/A	M	CIS 5.2	Sensitive file exposure

STEP 2 – Executive Summary

To: IT Management
From: GRC Audit Team
Date: 11th April, 2026
Subject: High-Risk Findings on Development Server 'metasploitable'

1. Executive Summary:
A vulnerability assessment of the internal server revealed multiple critical security vulnerabilities that pose an immediate and high risk to the organization's information assets. The system is non-compliant with several key organizational policies based on the CIS Controls and NIST CSF

2. Key Findings & Risks:

Critical Risk - Remote System Compromise: The FTP service contains a known backdoor (CVE-2011-2523) allowing attackers to gain full control without authentication. This violates our patch management policy (CIS Control 7.1).

High Risk - Data Interception: Services (Telnet, FTP) transmit credentials in plaintext, violating data protection standards (NIST CSF PR.DS-2) and risking credential theft.

High Risk - Weak Authentication: Default and weak passwords are in use, increasing the risk of unauthorized access (CIS 5.2).

3. Recommended Actions:

Immediate Isolation: Remove the server from the network until remediated.

Remediate: Apply security patches, especially for vsFTPD.

Harden: Disable unnecessary services (Telnet, Rlogin); enforce strong passwords.

Process Review: Reinforce procedures for deploying systems according to security baselines.

PHASE 4 – Quantitative Risk Analysis (SLE & ALE)

RISK ID	ASSET NAME	THREAT DESCRIPTION	AV	EF	SLE	ARO	ALE
R1	Customer Database	SQL Injection Attack	\$5,000,000	0.4	\$2,000,000	0.5	\$1,000,000
R2	Development Server	VsFTPD Backdoor	\$450,000	1.0	\$450,000	0.3	\$135,000
R3	Sensitive Data	Telnet/FTP	\$300,000	0.7	\$210,000	0.5	\$105,000
R4	Internal Accounts	Default Credentials	\$250,000	0.8	\$200,000	0.4	\$80,000
R5	Web Applications	Vulnerable Web Apps	\$400,000	0.6	\$240,000	0.35	\$84,000

STEP 2 – RISK TREATMENT STRATEGY

RISK ID	ALE	PROPOSED TREATMENT	JUSTIFICATION
R1	\$1,000,000	Mitigate	Implement WAF, input validation, and regular security audits to reduce likelihood and impact.
R2	\$135,000	Avoid	Disable FTP service completely.
R3	\$105,000	Avoid	Disable Telnet
R4	\$80,000	Mitigate	Enforce strong password policy + MFA.

R5	\$84,000	Mitigate	Update Apache and web applications + implement WAF.
----	----------	----------	---

STEP 3 – CONTROL MAPPING

Risk ID	Threat Description	Proposed Control	NIST 800 – 53 Control ID	Control Description
R1	SQL Injection Attack	Web Application Firewall	AC-4, SC-7	Information flow enforcement, boundary protection
R1	SQL Injection Attack	Input validation	SI-10	Information input validation
R4	Default Credentials		AC-2, IA-5	Account Management & Authenticator Management
R5	SQL Injection Attack	Web Application Firewall	SI-10, SC-7	Information Input Validation & Boundary Protection

Phase 5: Business Impact Analysis (BIA) Integration & Final Reporting

Risk ID	Threat Description	Affected Business Process	RTO	RPO	Financial Impact	Non-Financial Impact
R1	vsFTPd Backdoor	Development & Testing	4 hr	1 hr	\$60,000	IP theft, Regulatory fines

R2	Telnet/FTP	Administrative Access	8 hrs	0 hr	\$45,000	Data breach notification costs
R3	Weak Credentials	Access to Internal Systems	24hrs	4 hrs	\$35,000	Loss of customer trust
R4	Web App Vulnerabilities	Customer-Facing Applications	12 hrs	2hrs	\$55,000	Reputational damage, Legal liability